

Customer-Facing Compliance Report

Framework: HITRUST CSF v11

Primary audience: Healthcare covered entities, payers, providers, life-sciences organisations, and service providers preparing for or maintaining HITRUST CSF certification.

CSW positioning: Network segregation, vulnerability management with reachability, monitoring, and incident response evidence harmonised against the HIPAA / ISO 27001 / NIST 800-53 / PCI authoritative sources HITRUST CSF integrates.

Framework Version Note

References HITRUST CSF v11. HITRUST evolves the CSF periodically; assessment levels (e1, i1, r2) have different evidence requirements. Validate the version, assessment level, and authoritative-source mappings against the customer's HITRUST authoritative-sources list.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The technical runbook (CSW-HITRUST-Technical-Runbook.md) in this folder contains the deeper engineering detail.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW "certifies" compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer's compliance team, and the customer's assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does not replace the customer's governance, policy, or assessor judgement, and this report is not a control attestation.

Suggested CSW Scope Pattern

“

HITRUST-CSF

??? Regulated-Data-Systems (ePHI, PCI-CDE if applicable, PII)

??? Network-Segmentation-Boundary

??? Vulnerability-Management-Scope

??? Incident-Evidence

??? Third-Party-Egress

’

This scope pattern should be validated with the customer's architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- ? Network Protection / Segregation (HITRUST 09.m / 09.s; HIPAA Security Rule technical safeguards; ISO 27001 A.13; 800-53 SC-7 / AC-4)
- ? Vulnerability Management (HITRUST 06; 800-53 RA-5 / SI-2)
- ? Monitoring (HITRUST 09; 800-53 SI-4 / AU family)
- ? Incident Response (HITRUST 11; 800-53 IR family)
- ? Third-party / business-associate egress (HIPAA business-associate context)

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- ? Organisational policy, training, and governance domains
- ? Physical and environmental controls
- ? Identity lifecycle and access management beyond workload-to-workload
- ? Cryptography enforcement
- ? Business continuity testing
- ? HITRUST assessor scoring and certification decisions

Framework Topic ? CSW Capability Map

Framework topic	CSW capability	Evidence artifact
Network segregation	Policy workspace + workload-to-workload allowlist	Workspace snapshot + observed-vs-approved flow comparison
Vulnerability management	Reachability-weighted CVE on regulated workloads	Prioritised remediation list with compensating-control register
Monitoring	Continuous flow + process telemetry; alerts	Alert and anomaly log scoped to HITRUST-CSF
Incident response	Forensic flow + process search across the incident window	Investigation pack with timeline and impact scope
Business-associate / third-party egress	Outbound flow summary to BA / vendor endpoints	BA-edge flow report
Audit support	Periodic evidence pack	Quarterly evidence bundle aligned to HITRUST authoritative-source mappings

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

| Topic | What to collect | CSW source | Suggested cadence |
| | | | |
| Regulated-data system inventory | Workloads with ePHI / PCI / PII labels | Inventory +

scope membership export | Monthly |
| Segmentation evidence | Workspace snapshot + observed-vs-approved flow comparison | Policy
workspace export + ADM export | Quarterly + after each change |
| Vulnerability + reachability | CVE list weighted by reach into regulated-data systems |
Vulnerability report scoped to HITRUST-CSF | Monthly |
| Third-party egress reconciliation | Outbound flow to BA / vendor endpoints | Flow search
filtered to BA / vendor endpoints | Monthly |
| Incident timeline sample | One representative incident | Flow + process search | Per
incident |

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. tenant, prototype, isa_level, npi, cui, ephi').
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

CSW does not replace HITRUST authoritative-source policy, training, governance, the HITRUST assessor's scoring, identity lifecycle, encryption, physical and environmental controls, or HITRUST certification submission.

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.